# POST-INCIDENT RECORD — FORM ITSM-14

Complete one form per incident of severity SEV-3 or higher. All fields are mandatory.

| | |
|---|---|
| **1. Incident ref.** | INC-5388 |
| **2. Short title** | Authentication latency spike after configuration change; 22% of logins timed out |
| **3. Severity** | SEV-2 |
| **4. Service** | auth-service v5.9.4 (session issuance), edge-gw |
| **5. Environment** | Production — all regions |
| **6. Date of incident** | 2026-04-14 |
| **7. Duration** | 1 hour 38 minutes (09:41 – 11:19 UTC) |
| **8. Reported by** | Monitoring — alert AUTH-P99-LATENCY |
| **9. Incident manager** | J. Keller |
| **10. Form completed** | 2026-04-17 by J. Keller |

## 11. Description of the incident

A configuration change deployed to auth-service at 09:38 UTC on 14 April 2026 raised p99 login latency from 140 ms to just over 12 seconds. The edge gateway times out at 10 seconds, so 22% of login attempts returned a 504 to the customer. Sessions that were already established were unaffected, and no credentials were exposed or mishandled at any point.

The change set `session.signing.mode=strict`, which forces a fresh read of the signing key from the hardware security module for every token issued instead of using the in-process cached key. The HSM handles roughly 400 operations per second; login peak is 2,900 per second. Requests queued behind the HSM until they timed out.

Screenshot taken at 10:52 UTC and attached to the incident record.

## 12. Impact assessment

| Category | Assessment |
|---|---|
| Customers affected | ~148,000 failed login attempts; 61,000 unique accounts |
| Financial | CHF 22,000 estimated deferred revenue; no direct loss |
| Data | None. No credential exposure; no records modified. |
| Regulatory | Not reportable. Availability event, not a security event. |
| SLO | Login availability budget for April: 64% consumed |

## 13. Root cause

**The strict signing mode was enabled in production without capacity analysis against the HSM.** In strict mode every token issuance performs an HSM signing operation. The HSM's rated throughput of about 400 operations per second is roughly one seventh of peak login volume, so the request queue in front of it grew without bound and latency rose until requests hit the gateway's 10-second timeout. The setting had been validated in staging, where login volume is about 30 requests per second and the HSM is comfortably within capacity.

## 14. Detection and response checklist

**[X]** Incident detected by automated monitoring (not by a customer)

**[X]** Alert paged the correct on-call rota within 5 minutes

**[ ]** Rollback tested before being applied to production

**[X]** Customer communication issued

[X] Severity assigned within 15 minutes of detection

[X] Status page updated within 30 minutes

[X] Change causing the incident identified from the change log

[ ] Timeline of events recorded in this form

[X] Root cause established and stated above

[X] Actions raised in Jira with named owners and due dates

Where a box is unticked, explain below. — *Rollback was applied directly to production without a staging rehearsal, on the incident manager's authority, because the change was a single configuration key. Section 15 of this form was not completed; see note at item 17.*

## 15. Sequence of events

*[This section of the form has not been completed.]*

## 16. Action plan

| Jira | Action | Owner | Due | Status |
|---|---|---|---|---|
| IAM-611 | Revert session.signing.mode to cached and document that strict mode may not be enabled without an HSM capacity review. | J. Keller | 2026-04-15 | Done |
| IAM-612 | Add HSM operations-per-second to the pre-change checklist for any auth-service configuration change. | J. Keller | 2026-04-30 | Done |
| IAM-613 | Load-test staging at production-equivalent login volume before any signing-path change; provision a second HSM for the test environment. | A. Novak | 2026-05-29 | Done |
| IAM-614 | Add an HSM queue-depth alert that pages at 80% of rated throughput. | M. Dubois | 2026-05-08 | Done |

## 17. Notes

Item 15 was left blank. The bridge recording that the sequence would have been reconstructed from was not retained past its 72-hour expiry, and the form was completed on 17 April. The incident manager judged that an approximate sequence would be worse than none. This is itself raised as ITSM-90 (retain incident bridge recordings for 30 days), which is outside the scope of this record.

Signed: J. Keller, Incident Manager · Countersigned: R. Bianchi, Head of Platform · 2026-04-17